

Informe de Pentesting — INSECUR S.A.

Actividad A08 — Hacking Ético | Seguridad Aplicada a Sistemas de Información

Gonzalo Carbajal

Octubre de 2026

Portada y datos generales

Resumen ejecutivo

PARTE I — Pre-pentesting

Alcance del trabajo

Reglas de Enfrentamiento (ROE)

Autorización

Metodología utilizada

PARTE II — Desarrollo y hallazgos

2.1. Sala *Pentesting Fundamentals* (núcleo)

2.2. Sala *Basic Pentesting* (núcleo) — compromiso total hasta root

2.3. Sala *Nmap* (Nivel 2) — dominio de la herramienta de escaneo

Resumen ejecutivo de hallazgos

Post-pentesting — Recomendaciones

Recomendaciones técnicas (priorizadas por criticidad)

Recomendaciones administrativas (políticas y procesos)

PARTE III — Protocolo de contingencia

Escenario de falla

Impacto sobre la continuidad del negocio

Plan de respuesta

RTO y RPO estimados

Anexos

Anexo A — Bitácora de comandos

Anexo B — Capturas de pantalla

Anexo C — Hashes de las flags y credenciales obtenidas

Anexo D — Declaración ética firmada

Anexo E — Práctica complementaria: OWASP Juice Shop

Anexo F — Reto de esteganografía (desafío oculto en el material)

Fuentes y bibliografía

Portada y datos generales

Campo	Valor
Cliente	INSECUR S.A. (entorno ficticio de laboratorio)
Contratista (alumno)	Gonzalo Carbajal — Comisión G
Legajo / LU	31376904
DNI	(a completar por el alumno)
Username público de TryHackMe	gonzacarbajal18
Email de contacto	gonzacarbajal18@gmail.com
Sala de elección (Nivel 2)	Nmap (<i>Further Nmap</i> — <code>tryhackme.com/room/furthernmap</code>)
Branch de entrega en GitHub	carbajal-gonzalo
Fecha de inicio	06/10/2026
Fecha de cierre	07/10/2026

Nota sobre la entrega. La plantilla general de la cátedra menciona en su checklist un *Pull Request* hacia `main`. Sin embargo, el `README` de este repositorio indica expresamente lo contrario: la entrega se realiza en la rama personal y **abrir un PR descuenta 3/10**. Por eso entrego todo en mi rama `carbajal-gonzalo` y no abro ningún Pull Request.

Resumen ejecutivo

Me contrataron, en el marco de la actividad A08, para realizar una evaluación de seguridad de tipo *hacking ético* sobre los entornos de laboratorio de TryHackMe autorizados por la cátedra. El trabajo abarcó tres salas: dos del núcleo obligatorio (*Pentesting Fundamentals* y *Basic Pentesting*) y una de elección (*Nmap*).

El hallazgo más grave fue que, partiendo únicamente de una dirección IP y sin credenciales previas, logré **comprometer por completo la máquina de Basic Pentesting hasta obtener acceso de administrador (root)**. No fue por una única falla espectacular, sino por el efecto combinado de varias configuraciones débiles: un directorio web con información interna expuesta, una compartición de archivos accesible de forma anónima, una contraseña de SSH débil, una clave privada mal protegida y una reutilización de privilegios. Esto confirma la idea que arrastro desde la primera sala: *la enumeración es la clave*, y la seguridad se rompe por la suma de descuidos chicos, no siempre por un agujero enorme.

En total documenté **8 hallazgos**: 1 crítico, 3 altos y 4 medios. Para cada uno propongo una salvaguarda concreta. El informe cierra con un protocolo de contingencia pensado para que, si alguna de estas pruebas se replicara sobre un entorno productivo real de INSECUR S.A., el negocio pudiera recuperarse con el menor impacto posible.

PARTE I — Pre-pentesting

Alcance del trabajo

Dentro del alcance autorizado entraron **exclusivamente** las máquinas de laboratorio que la cátedra habilitó en TryHackMe:

- Sala *Pentesting Fundamentals* (teórica).
- Sala *Basic Pentesting* (máquina Linux, acceso por VPN de THM).
- Sala *Nmap / Further Nmap* (máquina Windows de práctica de escaneo).

Quedó **fuera del alcance** cualquier otro sistema: la infraestructura real de la facultad, la red doméstica desde la que trabajé, otras máquinas de TryHackMe no asignadas y, por supuesto, cualquier sistema de terceros. En ningún momento apliqué estas técnicas fuera de los laboratorios indicados.

Reglas de Enfrentamiento (ROE)

- **Permiso:** autorización académica de la cátedra para operar sobre los laboratorios de THM listados.
- **Test Scope:** sólo las IP que TryHackMe asigna al desplegar cada máquina, a través de la VPN oficial de la plataforma.
- **Reglas técnicas:**
 - Trabajé siempre conectado por la VPN de THM (`openvpn`), sin exponer tráfico fuera de ese túnel.
 - Los ataques de fuerza bruta se limitaron a diccionarios acotados y con pocos hilos (`-t 4`), para no degradar el servicio.
 - No realicé acciones destructivas (borrado de datos, denegación de servicio intencional).
 - Toda credencial o *flag* obtenida se documenta **ofuscada** (hash SHA-256), nunca en texto plano.

Autorización

Declaro que conté con **autorización expresa de la cátedra** para ejecutar estas pruebas sobre los entornos de TryHackMe mencionados, y que todas las actividades se realizaron con fines exclusivamente académicos, dentro de laboratorios controlados (*sandbox*).

Metodología utilizada

Seguí un enfoque alineado con **NIST SP 800-115** (*Technical Guide to Information Security Testing and Assessment*) y con las fases clásicas del pentesting profesional que estudié en *Pentesting Fundamentals*, apoyándome además en la **OWASP Web Security Testing Guide (WSTG)** para la parte web.

Elegí esta combinación por una razón práctica: NIST SP 800-115 me da el marco ordenado de fases (planificación → descubrimiento → ataque → reporte), que es auditable y reconocido; y OWASP me aporta el detalle fino cuando el objetivo es una aplicación web. Las fases que recorrí en cada máquina fueron:

1. **Reconocimiento** — identificación del objetivo y recolección de información.
2. **Escaneo** — descubrimiento de puertos, servicios y versiones (Nmap).
3. **Enumeración** — análisis en profundidad de cada servicio.
4. **Explotación** — aprovechamiento de una vulnerabilidad para obtener acceso.
5. **Post-explotación** — escalada de privilegios y consolidación del acceso.
6. **Reporte** — documentación y recomendaciones (este documento).

PARTE II — Desarrollo y hallazgos

2.1. Sala *Pentesting Fundamentals* (núcleo)

Esta primera sala es teórica y me sirvió para fijar el marco de trabajo que después apliqué. Los puntos que me llevo y que uso en todo el informe:

- Un pentest es un **ataque autorizado y ético**; lo que lo separa de un delito es el permiso por escrito y el alcance definido (la ROE).
- Mi rol en este trabajo es el de un **White Hat**: actúo dentro de la ley y con autorización.
- Existen metodologías formales (OSSTMM, OWASP, NIST SP 800-115, NCSC CAF) y modelos de caja **negra / gris / blanca** según cuánta información se tiene del objetivo. En *Basic Pentesting* trabajé en modo **caja negra** (sólo me dieron una IP).

Evidencia: `evidencias/reconocimiento/01_pentesting_fundamentals_completa.png` (sala completada, con mi usuario `gonzacarbajal18` visible).

2.2. Sala *Basic Pentesting* (núcleo) — compromiso total hasta root

Fue la máquina principal del trabajo. Arranqué sólo con la IP que me asignó THM, en modo caja negra. La resolví recorriendo las fases una por una, y terminé con acceso **root**. A continuación detallo el camino y, más abajo, cada hallazgo formalizado.

Recorrido resumido

1. **Escaneo (Nmap).** Un escaneo completo de puertos reveló 5 servicios: SSH (22), HTTP/Apache (80), SMB/Samba (139/445), un conector Tomcat (8009/AJP) y Apache Tomcat (8080). El objetivo era Linux/Ubuntu.
2. **Enumeración web.** Con `gobuster` encontré un directorio oculto `/development/` con notas internas (`dev.txt`, `j.txt`) firmadas por dos personas ("J" y "K"). Una de las notas admitía que el usuario "J" tenía una contraseña que se había podido crackear fácilmente.
3. **Enumeración SMB.** La compartición `Anonymous` era accesible sin credenciales. Dentro, un archivo `staff.txt` confirmaba los nombres de usuario: **jan** y **kay**.
4. **Explotación.** Con `hydra` hice fuerza bruta sobre el SSH del usuario `jan` y obtuve su contraseña. Ya tenía acceso al sistema como `jan`.
5. **Post-explotación.** Como `jan` pude **leer la clave SSH privada de kay** (estaba con permisos de lectura para todos). La clave estaba cifrada con *passphrase*, pero la crackeeé con `john` usando el diccionario `rockyou`. Entré como `kay`.
6. **Escalada a root.** `kay` pertenecía al grupo `sudo` y podía ejecutar cualquier comando. Con `sudo` obtuve `uid=0(root)`: **control total de la máquina.**

Evidencias principales: `02_nmap_basic_pentesting.png`, `03_enum_development_smb.png`, `04_hydra_jan.png`, `05_jan_shell.png`, `06_john_passphrase.png`, `07_root.png` (en esta última se ve `uid=0(root)`; la contraseña usada quedó tapada por prolijidad de seguridad).

Hallazgos formalizados

H-01 — Directorio web interno expuesto e indexable

Campo	Valor
Fase	Escaneo / Enumeración
Descripción	El servidor Apache exponía el directorio <code>/development/</code> con listado habilitado y notas internas de los desarrolladores (<code>dev.txt</code> , <code>j.txt</code>). Esa información reveló la existencia de dos usuarios y la pista de que uno tenía una contraseña débil.
Componente afectado	Servidor web Apache (puerto 80)
Categoría (OWASP/CWE)	OWASP A05:2021 <i>Security Misconfiguration</i> — CWE-538 <i>File and Directory Information Exposure</i>
CVE	No aplica (configuración)
CVSS estimado	Medio
Evidencia	<code>evidencias/escaneo/03_enum_development_smb.png</code> , <code>gobuster_80.txt</code>
Herramienta	<code>gobuster</code> , <code>curl</code>
Impacto CIA	Confidencialidad
Salvaguarda propuesta	Deshabilitar el <i>directory listing</i> en Apache (<code>Options -Indexes</code>), remover notas internas del servidor público y separar los entornos de desarrollo de los de producción.
Riesgo residual	Bajo

H-02 — Compartición SMB accesible de forma anónima

Campo	Valor
Fase	Enumeración
Descripción	La compartición Samba <code>Anonymous</code> permitía acceso sin autenticación. Contenía <code>staff.txt</code> , que filtraba los nombres de los usuarios del sistema (jan y kay), información clave para el ataque posterior.
Componente afectado	Servicio Samba (puertos 139/445)
Categoría (OWASP/CWE)	OWASP A01:2021 <i>Broken Access Control</i> — CWE-200 <i>Exposure of Sensitive Information</i>
CVE	No aplica (configuración)
CVSS estimado	Medio
Evidencia	<code>evidencias/escaneo/smb_staff.txt</code> , <code>enum4linux.txt</code>
Herramienta	<code>enum4linux</code> , <code>smbclient</code>
Impacto CIA	Confidencialidad
Salvaguarda propuesta	Deshabilitar el acceso anónimo (<code>guest ok = no</code> , <code>restrict anonymous = 2</code>), aplicar autenticación en todas las comparticiones y no almacenar información de personal en recursos compartidos.
Riesgo residual	Bajo

H-03 — Contraseña de SSH débil (fuerza bruta exitosa)

Campo	Valor
Fase	Explotación
Descripción	El usuario <code>jan</code> tenía una contraseña presente en diccionarios comunes (<code>rockyou</code>). Con <code>hydra</code> la obtuve en segundos, logrando acceso interactivo por SSH.
Componente afectado	Servicio SSH (puerto 22) — usuario <code>jan</code>
Categoría (OWASP/CWE)	OWASP A07:2021 <i>Identification and Authentication Failures</i> — CWE-521 <i>Weak Password Requirements</i>
CVE	No aplica
CVSS estimado	Alto
Evidencia	<code>evidencias/explotacion/04_hydra_jan.png</code> , <code>05_jan_shell.png</code> . Hash de la credencial en Anexo C.
Herramienta	<code>hydra</code>
Impacto CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Política de contraseñas robustas, bloqueo tras N intentos fallidos (fail2ban), autenticación por clave en lugar de contraseña y, de ser posible, MFA.
Riesgo residual	Bajo

H-04 — Clave SSH privada legible por todos los usuarios

Campo	Valor
Fase	Post-explotación
Descripción	La clave privada SSH de <code>kay</code> (<code>/home/kay/.ssh/id_rsa</code>) tenía permisos de lectura para cualquier usuario del sistema. Como <code>jan</code> , pude copiarla, lo que me abrió la puerta a la cuenta de <code>kay</code> .
Componente afectado	Sistema de archivos / cuenta <code>kay</code>
Categoría (OWASP/CWE)	CWE-732 <i>Incorrect Permission Assignment for Critical Resource</i>
CVE	No aplica (configuración)
CVSS estimado	Alto
Evidencia	<code>evidencias/post/05_jan_shell.png</code> (listado del <code>.ssh/</code> de <code>kay</code>). La clave no se versiona en el repositorio por higiene de seguridad.
Herramienta	<code>ssh</code> , <code>cat</code>
Impacto CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Permisos correctos sobre claves privadas (<code>chmod 600</code> , dueño exclusivo). Auditar periódicamente permisos de archivos sensibles.
Riesgo residual	Bajo

H-05 — Passphrase de la clave SSH débil (crackeable por diccionario)

Campo	Valor
Fase	Post-explotación
Descripción	La clave de <code>kay</code> estaba cifrada con <i>passphrase</i> , pero ésta figuraba en <code>rockyou</code> . Con <code>ssh2john</code> + <code>john</code> la recuperé casi instantáneamente, anulando la única protección que tenía la clave robada.
Componente afectado	Clave SSH de <code>kay</code>
Categoría (OWASP/CWE)	CWE-521 <i>Weak Password Requirements</i> / CWE-326 <i>Inadequate Encryption Strength</i>
CVE	No aplica
CVSS estimado	Medio
Evidencia	<code>evidencias/post/06_john_passphrase.png</code> . Hash en Anexo C.
Herramienta	<code>ssh2john</code> , <code>john</code>
Impacto CIA	Confidencialidad
Salvaguarda propuesta	Usar <i>passphrases</i> largas y aleatorias para proteger claves; combinar con el permiso correcto (H-04), ya que una cosa compensa a la otra.
Riesgo residual	Bajo

H-06 — Escalada a root por privilegios sudo totales (CRÍTICO)

Campo	Valor
Fase	Post-explotación
Descripción	El usuario <code>kay</code> pertenecía al grupo <code>sudo</code> y podía ejecutar <code>(ALL : ALL) ALL</code> . Con su contraseña (almacenada en claro en <code>/home/kay/pass.bak</code>) ejecuté <code>sudo</code> y obtuve <code>uid=0(root)</code> : compromiso total del sistema.
Componente afectado	Sistema operativo / cuenta <code>kay</code>
Categoría (OWASP/CWE)	OWASP A01:2021 <i>Broken Access Control</i> — CWE-250 <i>Execution with Unnecessary Privileges</i> / CWE-522 <i>Insufficiently Protected Credentials</i>
CVE	No aplica (configuración)
CVSS estimado	Crítico
Evidencia	<code>evidencias/post/07_root.png</code> (<code>uid=0(root)</code>), <code>root_flag.txt</code> . Hash de la credencial en Anexo C.
Herramienta	<code>ssh</code> , <code>sudo</code>
Impacto CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Aplicar mínimo privilegio (no todos los usuarios necesitan sudo total), no guardar contraseñas en archivos (<code>pass.bak</code>), rotar credenciales y usar un gestor de secretos.
Riesgo residual	Medio (el acceso privilegiado siempre conserva cierto riesgo y exige monitoreo).

2.3. Sala Nmap (Nivel 2) — dominio de la herramienta de escaneo

Elegí **Nmap** como sala de Nivel 2 (de la lista cerrada del enunciado). Es la herramienta que había usado en *Basic Pentesting*, y esta sala me permitió entender a fondo *por qué* funciona cada tipo de escaneo, no sólo usarlo.

Aprendizajes clave

- **Tipos de escaneo:** TCP Connect (`-sT` , completa el *handshake*), SYN “half-open” (`-sS` , más sigiloso, requiere sudo), UDP (`-sU` , lento), y los sigilosos NULL/FIN/Xmas (`-sN` / `-sF` / `-sX`) para evasión de firewall.
- **Interpretación de estados:** un puerto responde SYN/ACK si está **abierto**, RST si está **cerrado**, y no responde (*drop*) si está **filtrado** por un firewall.
- **NSE (Nmap Scripting Engine):** scripts en Lua agrupados en categorías (`safe` , `vuln` , `auth` , `brute` , `discovery` , `intrusive` ...). Verifiqué los argumentos y

dependencias de los scripts leyendo su código directamente en `/usr/share/nmap/scripts/`.

- **Evasión:** cuando el host bloquea ICMP (como el objetivo de esta sala), hay que usar `-Pn` para que Nmap no lo descarte como “caído”.

Práctica sobre el objetivo

El target era un **Windows Server (WIN-SCAN, Windows 10.0.17763)** que bloqueaba el ping, así que usé `-Pn`. Resultados:

- **Puertos abiertos (SYN scan, primeros 5000):** 5 → 21 (FTP), 53 (DNS), 80 (IIS), 135 (msrpc), 3389 (RDP).
- **Xmas scan (primeros 999 puertos):** los 999 aparecieron como `open|filtered` con razón `no-response` — consistente con el hecho de que Windows no responde de forma estándar a estos escaneos sigilosos (una limitación importante que un pentester debe conocer).
- **Script `ftp-anon`:** confirmó que el FTP **permitía login anónimo** (`FTP code 230`).

Evidencias: `evidencias/escaneo/12_nmap_sala.png` (servicios), `13_nmap_practical.png` (SYN + ftp-anon), `14_nmap_room_completed.png` (sala completada, usuario `gonzacarbajal18` visible).

Hallazgos formalizados

H-07 — Servidor FTP con login anónimo habilitado

Campo	Valor
Fase	Escaneo / Enumeración
Descripción	El servicio FTP (FileZilla) del servidor Windows objetivo permitía autenticación anónima. Confirmado con el script NSE <code>ftp-anon</code> (respuesta <code>230 Login successful</code>).
Componente afectado	Servicio FTP (puerto 21)
Categoría (OWASP/CWE)	OWASP A05:2021 <i>Security Misconfiguration</i> — CWE-287 <i>Improper Authentication</i>
CVE	No aplica (configuración)
CVSS estimado	Alto
Evidencia	<code>evidencias/escaneo/13_nmap_practical.png</code> , <code>nmap_ftpanon.txt</code>
Herramienta	<code>nmap --script ftp-anon</code>
Impacto CIA	Confidencialidad, Integridad
Salvaguarda propuesta	Deshabilitar el acceso anónimo al FTP, exigir credenciales, y preferir FTPS/SFTP sobre FTP plano.
Riesgo residual	Bajo

H-08 — Superficie de exposición amplia en el host

Campo	Valor
Fase	Escaneo
Descripción	El servidor exponía varios servicios de administración/red (FTP, DNS, IIS, msrpc y RDP en el 3389). Un RDP expuesto es un vector frecuente de ataques de fuerza bruta y ransomware.
Componente afectado	Host Windows completo
Categoría (OWASP/CWE)	OWASP A05:2021 <i>Security Misconfiguration</i>
CVE	No aplica
CVSS estimado	Medio
Evidencia	evidencias/escaneo/12_nmap_sala.png , nmap_syn_5000.txt
Herramienta	nmap -sS -sV
Impacto CIA	Confidencialidad, Integridad, Disponibilidad
Salvaguarda propuesta	Minimizar la superficie: cerrar/segmentar servicios innecesarios, exponer RDP sólo vía VPN, aplicar <i>host firewall</i> y mantener los servicios parcheados.
Riesgo residual	Medio

Resumen ejecutivo de hallazgos

Severidad	Cantidad	IDs
Crítico	1	H-06
Alto	3	H-03, H-04, H-07
Medio	4	H-01, H-02, H-05, H-08
Bajo	0	—
Total	8	H-01 ... H-08

Un patrón se repite: la mayoría de los hallazgos son **configuraciones débiles y credenciales mal manejadas**, no vulnerabilidades de software con CVE. Eso es coherente con lo que se ve en la industria: la mayor parte de los compromisos reales nacen de descuidos de configuración, no de *exploits* exóticos.

Post-pentesting — Recomendaciones

Recomendaciones técnicas (priorizadas por criticidad)

1. **(Crítico — H-06)** Aplicar el principio de **mínimo privilegio**: revisar quién tiene sudo y limitarlo. Eliminar contraseñas guardadas en archivos de texto (`pass.bak`) y adoptar un gestor de secretos.
2. **(Alto — H-03)** Imponer una **política de contraseñas fuertes** + bloqueo por intentos fallidos (fail2ban) + autenticación por clave SSH en lugar de contraseña.
3. **(Alto — H-04)** Corregir **permisos de claves privadas** (`chmod 600` , dueño exclusivo) y auditar permisos de archivos sensibles periódicamente.
4. **(Alto — H-07)** Deshabilitar **FTP anónimo**; migrar a SFTP/FTPS.
5. **(Medio — H-01/H-02)** Deshabilitar *directory listing* en el web y el **acceso anónimo a SMB**; separar desarrollo de producción.
6. **(Medio — H-05)** Usar *passphrases* largas y aleatorias en las claves.
7. **(Medio — H-08)** Reducir la **superficie de exposición**: RDP sólo por VPN, firewall de host, servicios innecesarios apagados.

Recomendaciones administrativas (políticas y procesos)

- **Política de contraseñas y gestión de accesos** formal, con revisión periódica de usuarios privilegiados.
- **Capacitación** a desarrolladores y administradores sobre higiene de credenciales y de configuración (buena parte de estos hallazgos nacen de descuidos humanos).
- **Hardening** documentado y revisiones de configuración (baselines CIS) antes de pasar a producción.
- **Auditorías periódicas** y un pentest recurrente como el presente.

PARTE III — Protocolo de contingencia

Escenario de falla

El procedimiento con mayor riesgo de causar una interrupción en un entorno productivo real sería el **ataque de fuerza bruta (H-03)** y, en segundo lugar, los **escaneos agresivos/sigilosos**. Un `hydra` mal calibrado puede bloquear cuentas de usuario (si hay política de *lockout*) o saturar el servicio de autenticación; un escaneo SYN o `-A` sobre un servicio inestable puede llegar a tirarlo abajo.

Impacto sobre la continuidad del negocio

Si esto ocurriera sobre producción de INSECUR S.A., los procesos afectados serían el **acceso de los usuarios legítimos** (cuentas bloqueadas) y la **disponibilidad del servicio** escaneado. El impacto estimado sería de **minutos a un par de horas**, según la rapidez de detección y respuesta.

Plan de respuesta

1. **Activación (detección):** alertas del IDS/SIEM por volumen anómalo de intentos de login o por caída de un servicio; reportes de usuarios que no pueden ingresar.
2. **Contención (primeros 15 minutos):** cortar el origen del tráfico (bloqueo de IP en el firewall), pausar el procedimiento de prueba y aislar el servicio afectado.
3. **Recuperación:** desbloquear las cuentas afectadas, reiniciar el servicio caído desde un estado sano (rollback / servidor espejo / restauración de backup si corresponde).
4. **Comunicación:** notificar a la dirección de TI, al responsable del servicio y —si hubiera impacto a clientes o datos— a las áreas legales y a los afectados, según la política interna.
5. **Post-mortem:** documentar causa raíz, tiempo de recuperación y lecciones aprendidas; ajustar la ROE de futuras pruebas para que no vuelva a pasar.

RTO y RPO estimados

- **RTO (Recovery Time Objective):** 2 horas.
- **RPO (Recovery Point Objective):** 24 horas (según la frecuencia del último backup).

Anexos

Anexo A — Bitácora de comandos

Los comandos ejecutados y sus salidas (ya redactados, sin secretos en claro) están en la carpeta `bitacora/` :

- `bitacora/basic_pentesting_20261007.txt`
- `bitacora/sala_nmap_20261007.txt`
- `bitacora/juiceshop_20261007.txt` (*anexo complementario, ver Anexo E*)

Anexo B — Capturas de pantalla

Organizadas por fase en `evidencias/` :

Archivo	Descripción	Hallazgo
reconocimiento/00_vpn_conectada_*.png	Conexión a la VPN de THM (terminal + web)	—
reconocimiento/01_pentesting_fundamentals_completa.png	Sala <i>Pentesting Fundamentals</i> completada	—
escaneo/02_nmap_basic_pentesting.png	Nmap de <i>Basic Pentesting</i>	H-01
escaneo/03_enum_development_smb.png	/development/ + staff.txt	H-01, H-02
explotacion/04_hydra_jan.png	Fuerza bruta SSH (jan)	H-03
post/05_jan_shell.png	Acceso como jan + clave de kay	H-03, H-04
post/06_john_passphrase.png	Crackeo de passphrase con John	H-05
post/07_root.png	Escalada a root (uid=0)	H-06
escaneo/12_nmap_sala.png	Servicios del target (sala Nmap)	H-08
escaneo/13_nmap_practical.png	SYN scan + ftp-anon	H-07
escaneo/14_nmap_room_completed.png	Sala <i>Nmap</i> completada	—

Anexo C — Hashes de las flags y credenciales obtenidas

Por higiene de seguridad **no publico valores en claro**; sólo su hash SHA-256 (verificables por la cátedra).

```
# Basic Pentesting – credenciales
Password SSH de 'jan'
9eb6835cc95b053818b660bd9fc9f092a0b30cef89c1f0f17f469d5caa0ae617
Passphrase clave id_rsa de 'kay'
873504f0103a88d762191a358f4aa432dbbcf8af64f19dd913d7f8f925191a08
Password de 'kay' (pass.bak)
3ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
```

(Los hashes de los desafíos de la práctica complementaria de Juice Shop están en evidencias/explotacion/flags_juiceshop_hashes.txt.)

Anexo D — Declaración ética firmada

Declaro que todas las actividades descritas en este informe se realizaron **dentro del alcance autorizado**, en entornos controlados de laboratorio (TryHackMe) y con fines **exclusivamente académicos**. No apliqué ninguna de estas técnicas sobre sistemas reales ni fuera del alcance acordado con la cátedra.

Anexo E — Práctica complementaria: OWASP Juice Shop

Aclaración: Juice Shop **no** es mi sala de Nivel 2 (ésa es Nmap, de la lista del enunciado). La incluyo como práctica adicional porque la habíamos empezado en clase y quise terminarla por mi cuenta para afianzar las vulnerabilidades web del OWASP Top 10.

Trabajé sobre la aplicación deliberadamente vulnerable **OWASP Juice Shop** y resolví, entre otros, estos desafíos:

- **Reconocimiento:** descubrí el *Score Board* oculto (`/#/score-board`) y, explorando reseñas de productos, el email del administrador.
- **Inyección SQL (A03):** me logueé como administrador y como “Bender” inyectando `' or 1=1--` y `bender@juice-sh.op'--` en el formulario de login, sin credenciales válidas.
- **Autenticación rota (A07):** recuperé la contraseña del administrador por fuerza bruta contra el endpoint `/rest/user/login`, y reseteeé la contraseña de “Jim” respondiendo su pregunta de seguridad (deducida de una reseña suya: *Star Trek* → *Samuel*).

Las capturas están en `evidencias/` (`08`, `09`, `10`, `11`) y los hashes de los *flags* en `evidencias/explotacion/flags_juiceshop_hashes.txt`.

Anexo F — Reto de esteganografía (desafío oculto en el material)

Revisando a fondo el material del repositorio de la cátedra, detecté un **desafío oculto** (esteganografía de doble capa) descrito en `Estenografía.tex` e implementado en las imágenes `RedTeamKey.jpg` y `BlueTeamFinal.jpg`. Lo resolví así:

1. `steghide extract` sobre `RedTeamKey.jpg` (passphrase vacía) → recuperé una **llave** de texto.
2. `steghide extract` sobre `BlueTeamFinal.jpg` → obtuve un archivo cifrado con OpenSSL (AES-256-CBC).
3. Descifré ese archivo usando la llave recuperada (`openssl enc -d -aes-256-cbc -pbkdf2`) → obtuve el mensaje/token oculto.

Por indicación del propio mensaje, el contenido es privado y lo comunico al docente por canal directo. Aquí dejo únicamente su **hash SHA-256** como prueba de que lo resolví, sin exponerlo:

Mensaje/token descifrado

e9189b8c9d13cd402f59f4935ac8947a10f84717d802dac7f1f3badfe6f0441a

Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals* — tryhackme.com/room/pentestingfundamentals
- TryHackMe. *Basic Pentesting* — tryhackme.com/room/basicpentestingjt
- TryHackMe. *Further Nmap* — tryhackme.com/room/furthernmap
- OWASP Foundation. *Web Security Testing Guide (WSTG)*. Material de cátedra: [GuiaOWASP.pdf](#).
- Lyon, G. *Nmap Network Scanning* — guía de referencia. Material de cátedra: [Nmap-Network-Mapper.pdf](#).
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.ª ed.). IC Editorial.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace.